

s or outputs are not clear enough to confidently assess whether the issue is actionable and how much of the milestone it would consume, it needs to be refined.

3. Add appropriate weighting & labels to the issue based on the estimated time to investigate, research and deliver the documented outputs.

4. Request help/assistance from other parties when the issue requires cross team collaboration during planning if possible.

Issue Weighting

This is the scale used to size issues for scheduling. Note, the estimated durations are referring to overall effort, not scheduling duration. For example, if a large task can have several small tasks created and parallelized, it may be completed in less than 4+ weeks of scheduled time, but still be appropriately sized as a large work item.

Issues should be labelled with a development label to describe the expected level of effort required.

Additional Labels Used

In addition to the sizing labels detailed in the previous section, the following labels are used in prioritization and planning.

| Label | Purpose | Scoped |

|---|---|---|

| ~"vuln-mgmt-BAU" | This issue represents work which is part of regular or BAU ("business as usual") activities, which do not require explicit planning | No |

| ~"vulnerability-management-tooling::" | Scoped label indicates which tool or automation this issue relates to. To be used for tooling owned by Vulnerability Management | Yes |

SECTION: security/readmes/_index.md

SECTION: security/readmes/byron-boots.md

Hi, I'm Byron, and you can read about me here

SECTION: security/readmes/joseph-longo.md

Related pages

- LinkedIn Profile
- GitLab Profile

My working style

- I don't like to micro-manage. As long as results are being delivered, I try to give others the freedom to operate on their terms. If you require additional instructions or guidance in order to complete a task, don't hesitate to ask. I try to tailor my management and working style to the different individuals I am working with.
- I tend to ask a lot of questions to ensure I have the full context before making a decision. The more information you can provide, the faster and easier the decision making process will be for me.
- I strive to empower my team and help them reach their full potential. If there are topics or cross-functional areas that you're interested in, let me know, and we'll find a way to help you engage in those topics and reach your goals.

For your situational awareness (FYSA)

- I tend to overexplain sometimes. I put a lot of thought into decisions I make, and when conveying those decisions, I often explain the entire journey I took to come to reach the end. If this happens, and it's not valuable to you, please don't hesitate to stop me and ask for the Cliffs Notes version.
- When I'm busy, I will often look at Slack messages or emails and mark them as unread. While I intend to follow up on those messages when my bandwidth increases, I can sometimes forget. Don't hesitate to send me a reminder if you haven't received a response within your expected window.

Communication

- I always appreciate brutal honesty. Direct communication is the quickest way for me to learn and make changes.
- I'm always monitoring Slack and email. Feel free to reach out at any time.
- I'm a big supporter of asynchronous communication, but I also believe a quick call or Slack huddle (< 5 mins.) can sometimes be the more efficient way to solve a problem. Don't be afraid to propose a call, I'll let you know if async works better at that time.

SECTION: security/readmes/josh-lemos.md

Why I'm at GitLab

GitLab builds a platform with the potential to improve security assurance at internet scale. Having spent a decade leading teams that engineered security solutions into homegrown CI/CD systems, I saw an opportunity to move beyond single-company solutions that served thousands of developers to work on a platform that could secure millions. At GitLab, we have the opportunity to improve software security globally. What keeps me at GitLab is the wealth of smart, dedicated team members committed to the same mission.

Throughout my life and career I have sought out difficult challenges. Leading a security division at the most public public-company is one of the most challenging CISO roles in the world. It is a great privilege to help lead this company on our security journey as a DevSecOps company.

Leadership Philosophy

People are the foundation of organizational success and the most fascinating aspect of any enterprise. This is particularly true in information security, where securing human behavior has been an ongoing challenge for decades. My mission is to create environments where exceptional individuals can thrive and drive remarkable outcomes while fostering a culture of meaningful contribution.

Personal Values

- Candor: High-fidelity information drives decision-making. I encourage open dialogue and positive intent, believing that even difficult issues become solvable when discussed openly.
- Integrity: Maintain rigorous accountability standards and act in good faith, regardless of circumstances or audience. Reputation and trust is currency in the security community.
- Ownership: Success multiplies when people feel true ownership of objectives. I believe in pushing decisions to those closest to the problems.

My Super Powers

- Accountability: I deliver on commitments and maintain high performance standards, communicating proactively when plans need adjustment.
- Building High-Performing Teams: Complex systems require collaborative effort. I value acknowledging both strengths and growth areas in building high-performing teams. I create environments where team members can do their best work, a place where they make their career highlight reel.
- Persistence & Grit: My achievements come through determination and resilience rather than natural talent. I'm willing to fail and learn repeatedly on the path to success.
- Humor: While I take our security mission seriously, I believe in maintaining perspective through appropriate levity, especially following high-pressure situations once threats are mitigated.

My Weaknesses

- Malcontent: My drive for improvement can sometimes overshadow celebrating progress. Please remind me to acknowledge wins.
- Impatience: When biasing for action I may at times move too quickly to solutions in areas of expertise. Feel free to encourage more discussion time.
- Complacency: I have limited patience for learned helplessness, I expect others to share my drive for seeking better solutions. Don't stay blocked.

Working Together

Expectations

- Problem Solving: Expect first-principles thinking and data-driven approaches

- Ownership: Clear DRIs (Directly Responsible Individuals) for all initiatives

- Growth Mindset: Continuous learning through active coaching and feedback

- Customer Focus: Alignment between business objectives, OKRs, and security strategy

- Healthy Conflict: Embracing diverse perspectives and data-grounded discussions

Communication Preferences

- Primary: Slack is my default communication channel

- Documentation: Comments in shared documents (tag me directly). I prefer to write and communicate in long-form content rich documents

- Meetings: Reserved for discussions that can't be resolved asynchronously

- Email: Long-form, non-urgent communications

- Phone/Signal: Emergency and off-hours communication

My Role as CISO

Secure GitLab's platform, customers, and company against cyber threats.

Key Performance Indicators

- Incident SLA compliance

- Asset inventory coverage

- Time to containment

- Internally identified vulnerabilities

Expectations for leadership - What I need from you. What you will get from me

- Be Proactive: Push information rather than waiting to be asked

- Challenge Norms: Take principled risks and question the status quo

- Show Integrity: Own failures, celebrate team successes

- Embrace Divergent Perspectives: Seek out and value different perspectives

- Communicate Clearly: Default to transparency and structured communication

Remember: I value direct feedback. If you see areas where I can improve or better support you, please let me know.

SECTION: security/readmes/julie-davila.md

Please view my README at <https://gitlab.com/juliedavila/juliedavila/-/blob/main/README.md>

SECTION: security/readmes/nick-malcolm.md

{{% include-readme username="nmalcolm" %}}

SECTION: security/readmes/philippe-lafoucriere.md

Philippe Lafoucrière's README

About me

Hi! I'm a Security Architect at GitLab, which is a specialty on top of my Security Distinguished Engineer role.

I have an Engineering background, having graduated from the Université de Technologie de Compiègne (France) with a Master's Degree in Computer Science. Nevertheless, my career almost involved an Entrepreneur aspect. This makes me a Jack of all trades and a master of none.

I have worked in various industries, ranging from telecoms to online betting.

A few facts about me:

- I live in Quebec City, Quebec, Canada.
- I have dual citizenships: French & Canadian.
- I have 2 teenagers.
- I have lived, studied and worked in France and other European countries, but also in South East Asia.
- I spent some of my childhood in South Pacific Islands near Australia.
- I love all things outdoors.

Background story at GitLab

I joined GitLab with the acquisition of Gemnasium in 2018, when I became the first manager of the Secure Stage. After having designed and developed security products, I decided to switch to the other side of the mirror and joined the Security Department in 2020.

Communicating with me

I'm pretty informal, message me on Slack, send an email, or tag me on a thread, and I'll respond as soon as I can. I don't use TODOs in GitLab, preferring to use emails instead. This allows me to see updates on issues where I've been involved, without getting pinged explicitly.

You can always book a slot in my agenda (during working hours) if you want to talk to me, no need to ask.

My English is not perfect. The best way for me to improve is to correct myself when I'm using wrong words or expressions.

Also, you can tell I'm tired when my English is worse than usual!

My working style

I live by our values and embrace every one of them as much as I can. By default, I will go async via an issue or a merge request. I create a lot of issues, but they do not all translate into an action item. I use issues as a placeholder for discussions too. Sometimes, it's to document why I or we think it's not a good idea to do something. We can re-evaluate the topic long after, and still get the context which might have changed in the meantime.

I enjoy merge requests too, and consider them as the new workspace. They invite everyone to contribute, keep track of context and changes, let us loop in whoever is needed to review or approve, and at least but not least have great flexibility for approval rules.

I love UX and by extension simplicity, which is something I will always strive for. Complexity is growing exponentially, so I tend to push back on ideas that can be simplified.

Having managed a company for a decade, I have an affinity for:

- added value: Return On Investment (ROI) is a great way to think about the value provided when a decision is made. In everything I'm doing or planning to do, I'm always asking myself what my added value in this matter is. How do I contribute to the success of the Security Department and GitLab, the product and the company.
- risk assessment and management: Blind spots and dark corners keep me up at night. Legal and security risks can arise everywhere, and I usually have a natural ability to find and recognize them.

Typical workday

I wake up at 6 am, exercise until 8 am, breakfast until 8:30 am I usually don't work before this time, but always check my emails and slack messages when I wake up (old CEO habit).

I take a 1-hour break for lunch, usually between 11:30 am - 12:30 pm.

I end the day around 6 pm to cook dinner for the family.

I get back to the computer between 7 and 8 pm After that, Slack and emails are still in "monitor mode", but it's usually family time.

Projects

I maintain the GitLab Inventory Builder as well as our internal inventory (private project).

Office Hours

As a Distinguished Engineer, I host Office Hours for the Security Department, but anyone else is free to join if you want to talk about security. These Office Hours usually happen on Mondays at 9:30 AM PST (the event is stored in the "Security" shared calendar, available to all team members of the department). Reach out to me if you're not in this department and want to be invited.

Roadmap and Vision

My roadmap and vision can be found [here](#).

Tooling

These tools make my day, every single day. I would have a really hard time working without:

Alfred

Alfred is a productivity app for mac. It's a blazing-fast application launcher with some nice extra features. The best is the clipboard history that stacks everything copied in the clipboard. I can copy many different links for example and then switch to another window to paste them. It's also smart enough to remove secrets from 1password from the history once pasted.

Little Snitch

Little Snitch is a smart firewall for Mac. It monitors all traffic and lets me choose what I accept or not. More importantly, it will trigger a pop-up when a new and unexpected connection is initiated, so I can spot if a program is trying to send something behind my back.

SECTION: security/readmes/ty-dilbeck.md

Hi, I'm Ty, and you can read about me [here](#)

SECTION: security/security-and-technology-policies/access-management-policy.md

Purpose

This policy is intended to outline the access management controls implemented by GitLab.

Scope

These controls apply to information and information processing systems at the application and operating system layers, including networks and network services.

Roles & Responsibilities

Role	Responsibility
Security Assurance	Responsible for implementing and executing this policy
Business or System Owners	Alignment to this policy and any related standards
Security Assurance Management (Code Owners)	Responsible for approving significant changes and exceptions to this policy
Team Members	Responsible for adhering to the requirements of this policy

Policy

Access requests and reviews

Access requests are opened for all new or changing access. (AC-2)

Access requests are approved prior to making access changes. (AC-2)

Access requests and reviews are documented. (AC-2, AC-6(7))

An exception process exists for access requests.

Access revocation

Access is deprovisioned upon cessation of employment. (AC-2(3))

Job transfers

Access is deprovisioned or provisioned upon job transfer, as appropriate for the transfer. (AC-2, AC-2(3))

Access reviews

Access reviews are performed to confirm existing access. (AC-6(7))

Access Management Standard

For further details on GitLab's access management processes, please review the Access Management Standard in the Internal Handbook.

Exceptions

Exceptions to this policy will be tracked as per the Security and Technology Policy Exception Management Process.

SECTION: security/security-and-technology-policies/audit-logging-policy.md

Purpose

To ensure the proper operation and security of GitLab.com, GitLab logs critical information system activity.

Scope

The audit logging policy applies to all systems within our production environment. The production environment includes all endpoints and cloud assets used in hosting GitLab.com and its subdomains. This may include third-party systems that support the business of GitLab.com.

Roles & Responsibilities

Role	Responsibility
GitLab Team Members	Responsible for following the requirements in this policy
Security Team	Responsible for implementing and executing this policy
System Owners	Definition of individual audit log criteria; Definition and execution of system audit log procedures
Security Management (Code Owners)	Responsible for approving significant changes and exceptions to this policy

Policy

- GitLab shall log and monitor critical information system activity.
- Logs must be retained for a defined period of time.
- Logs must not be modified and or deleted.
- Access to audit log data must be limited based on the principle of least privilege.

Inline with GitLab's Continuous Monitoring Controls

System Owners are responsible for determining what constitutes "critical information system activity" in their respective system based on their experience and professional judgement

Such activity is then documented either in the handbook or a runbook, whichever is found to be appropriate.

Audit logging process must be created and implemented by the department(s) or team(s) responsible for a given system.

Exceptions

Exceptions to this policy will be tracked as per the Information Security Policy Exception Management Process.

References

- What is considered production
- Production Architecture

- Configuration Management

SECTION: security/security-and-technology-policies/change-management-policy.md

Purpose

This policy is intended to outline the change management controls implemented by GitLab.

Scope

Changes, in the context of this policy, are defined as modifications, including, but not limited to:

- Creation/development/implementation of new systems, integrations, features, key reports, databases, etc.
- Changes to configurations
- Deployment of patches or vendor supplied changes not managed by the vendor
- Modifications to data schemas
- System deprecation
- New access or role creation
- Broadly speaking, any change that will impact how team members carry out their responsibilities

The policy applies to changes that are made to systems assigned a Critical System Tier of Tier 1 Mission Critical, Tier 2 Business Critical, and Tier 3 Business Operational.

{{% note %}}

While Tier 4 Administrative systems are not subject to the scope of this policy, team members are encouraged to proactively adopt the requirements established by this policy across all systems, especially if there is a good probability that a system may move from a Tier 4 Administrative system to a higher system tier handbook page.

{{% /note %}}

Roles & Responsibilities

Role	Responsibility
Security Compliance Team	Responsible for the continuous monitoring of change management procedures across the relevant systems through security control testing to ascertain adherence to this policy
Technical System Owners Business System Owners System Administrators	Responsible for ensuring the minimum requirements established by this policy are implemented in procedure and executed consistently
Team Members	Responsible for following change management procedures in a way that aligns with this policy
Control Owners	Responsible for defining and implementing change management procedures that meet or exceed the minimum requirements that have been established by this policy

Policy

Changes are documented in accordance with the relevant procedures. (CM-3)

Changes may undergo testing in accordance with the relevant procedures. (CM-4)

Changes are reviewed by appropriate stakeholders. (CM-3, CM-4)

Changes are approved by appropriate stakeholders. (CM-3)

Changes are deployed in accordance with the relevant procedures. (CM-5)

Standard

For further details, please review GitLab's Change Management Standard and the procedures linked within.

Exceptions

Exceptions to this policy will be tracked as per the Security and Technology Policy Exception Management Process.

References

- Infrastructure Change Management Procedure
- Business Technology Change Management Procedure (internal only)
- Organizational Change Management Procedure
- Security Change Management Procedure

SECTION: security/security-and-technology-policies/penetration-testing-policy.md

A penetration test is a process to identify security vulnerabilities in an application or infrastructure in order to evaluate the security of the system.

Purpose

This policy is intended to outline the penetration testing controls implemented by GitLab.

Scope

These controls apply to the applications and systems that fall within the scope of each specific penetration test.

Roles & Responsibilities

Role Responsibility

---- -----

GitLab Team Members Responsible for following the requirements in this policy

| Security Team | Responsible for implementing and executing this policy |
| Security Management (Code Owners) | Responsible for approving significant changes and exceptions to this policy |

Policy

Planning

A third-party penetration test is conducted at least annually. (CA-8, SC-7(10))

GitLab utilizes a reputable third-party penetration testing firm to conduct the penetration test. (CA-8(1))

A scope and testing methodology is determined for each penetration test. (CA-8)

Objectives and goals are established prior to the start of each test. (CA-8)

Execution

Penetration tests are performed in accordance with the scope and methodology established during the planning phase. (CA-8)

Reporting

Penetration test results are documented and distributed to appropriate team members.

Remediation

Findings from penetration tests are assessed and addressed in accordance with GitLab's Vulnerability Management Standard (SI-2, RA-5)

Retests

Retests may be performed to validate changes made during the remediation phase. (CA-8)

Standard

For further details, please review GitLab's Penetration Testing Standard.

Exceptions

Exceptions to this policy will be tracked as per the Security and Technology Policy Exception Management Process.

SECTION: security/security-and-technology-policies/security-and-technology-policies-management.md

Purpose

This policy is intended to establish requirements for the creation and management of security and technology related policies.

Scope

This policy applies to security and technology policies that fall within the scope of GitLab's security compliance audits and assessments.

Roles & responsibilities

Role	Responsibility
Security Governance Team	Responsible for conducting annual controlled documents review and enforcing this policy
Security Assurance Management (Code Owners)	Responsible for approving changes to this policy

Policy

Policy creation and requirements

All in-scope policies must be created as version controlled documents in GitLab.

All in-scope policies must be listed in the policies section of the CODEOWNERS file with appropriate stakeholders listed as codeowners.

At a minimum, all in-scope policies must include a purpose, scope, roles and responsibilities, and policy statements.

All policy statements for in-scope policies must be mapped to the appropriate GCF control(s).

Policy review and approval

All in-scope policies must be reviewed and approved by appropriate stakeholders prior to merging the initial MR to create the policy.

All in-scope policies must be reviewed and approved by appropriate stakeholders on at least an annual basis in coordination with the Controlled Document Procedure annual review.

Policy communication and training

New and updated policies must be communicated to relevant team members upon creation or material update.

Relevant in-scope policies must be acknowledged by team members during onboarding training and annually thereafter.

SECTION: security/security-and-technology-policies/software-development-lifecycle-policy.md

Purpose

Secure software development is critical to developing and maintaining a safe and trusted application. This policy outlines the general components of GitLab's software development lifecycle.

Scope

This policy applies to anyone developing, reviewing, and merging code at GitLab in support of GitLab's production applications.

Roles and responsibilities

Role	Responsibility
Security Governance	Responsible for creating and implementing this policy
Team members	Responsible for execution of the policy statements

Policy

In-scope development activities are performed in accordance with GitLab's product development flow. (SA-3)

Development activities are performed with security, confidentiality, and availability principles in mind. (PL-8, SA-8)

Test data used throughout the development process is subject to GitLab's Data Classification Standard (SA-3(2))

Standard

For further details, please review GitLab's Software Development Lifecycle Standard.

Exceptions

Exceptions to this procedure will be tracked as per the Information Security Policy Exception Management Process.

SECTION: security/security-assurance/_index.md

<link rel="stylesheet" type="text/css" href="/stylesheets/biztech.css" />

<i class="fas fa-rocket" id="biz-tech-icons"></i> Security Assurance Mission and Vision

Our mission is to provide a high level of assurance that Gitlab (the platform and company) is secure.

Our vision is to be a trusted sales enablement partner that is recognized internally and

externally for its collaborative and transparent security assurance program, powered by AI and automation. This will be achieved through 10 strategic objectives:

- 1. Establish GitLab as a thought leader in DevSecOps and AI.
- 1. Accelerate the sales cycle to enable Sales to acquire new customers and reduce customer churn.
- 1. Align Security Assurance with strategic business objectives and develop oversight for continuous alignment
- 1. Enhance the efficiency and effectiveness of Security Assurance through automated and custom-built solutions
- 1. Facilitate strategic initiatives to expand and improve GitLab's external Security brand.
- 1. Identify, manage, and reduce security risk through cross-functional collaboration, strategic prioritization, and proactive mitigation including governance over data security and resilience programs.
- 1. Proactive compliance initiatives to maintain competitive advantage and enable customer acquisition through alignment with regulatory and industry specific requirements.
- 1. Intra-division collaboration to enable successful, timely, and cost effective program and project initiation, management, and delivery through repeatable and scalable processes with consistent measurement and actionable reporting.
- 1. Influence product development and enhancement through deliberate use and delivery of actionable feedback.
- 1. Intra and Inter-division collaboration to enable effective and efficient identification and remediation of compliance findings.

Security Assurance Department Structure

There are four teams in the Security Assurance department.

<i>Hands Helping</i> Governance & Field Security
<i>Bullseye</i> Security Compliance
<i>Shield</i> Security Risk
<i>Tasks</i> Security Program Management

Governance Team Page	Field Security Team Page
Security Compliance Team Page	Security Risk Team Page
Security Program Management Team Page	

Core Competencies

Field Security Core Competencies

- Sales Training (Security)
- Sales Enablement (Security)
- Customer Assurance (Security)
- Security Evangelization

Security Governance Core Competencies

- Security Policies, Standards and Control maintenance
- Security Assurance Metrics
- Regulatory Landscape Monitoring
- Security Awareness and Training
- Security Assurance Application Administration
- Security Assurance Automation

Security Risk Core Competencies

- Security Third Party Risk Management
- Tier 2 Operational Security Risk Management
- Business Impact Assessments

- Critical System Tiering

Security Compliance Core Competencies

- Continuous Control Monitoring
- Security Certifications and Attestations
- User Access Reviews (non-SOX)
- Observation management for control failures and Tier 3 (system-level) risks
- GitLab Production Readiness: Compliance Assessment

Core Tools and Systems

The Security Assurance sub department utilizes a variety of tools to carry out day to day activities. The system admin is responsible for the following:

- Configuration changes
- Onboarding/offboarding/transfers (ie Access)
- Upgrades/patching/incidents
- Migrations to new environments
- Restores from backup
- Admin level audit evidence
- Quality oversight (limited scope)

All other actions are the responsibility of the assigned DRI.

System Name	System Description	Admin	DRI
Hyperproof	Key system utilized for initiating, tracking/documenting, and completing Governance, Risk, and Compliance related activities.	Donovan Felton	Security Compliance - Madeline Lake Security Risk - Ty Dilbeck
Authomize	Key system utilized by Security Compliance for User Access Reviews	Alex Frank	Platform - Alex Frank Custom Connectors - Byron Boots
Safebase	Trust center solution to host security collateral for customers to request.	Donovan Felton	Joe Longo
ProofPoint	Key system utilized for the creation and distribution of our security training and phishing simulations to provide ongoing testing for adherence of various compliance frameworks.	Donovan Felton	Joe Longo
BitSight	BitSight is used to assess and monitor software vendors as part of our Security Third Party Risk Management Program.	Ryan Lawson	Ty Dilbeck
GitLab	Security Assurance Projects	Primarily used to engage stakeholders via issues, updates to Security Assurance related handbook pages, etc.	Security Assurance Senior Director
Each Team is responsible for their Projects, but everyone can contribute			

Contacting the Team

- Join our slack channel: sec-assurance
- Email: <security-assurance@gitlab.com>

Team READMEs

- Byron's README

<i class="fas fa-book" style="color:rgb(110,73,203)" aria-hidden="true"></i> References

Check out these great security resources built with our customers in mind:

- GitLab's Customer Assurance Package
- GitLab's Security - Trust Center
- GitLab's Security Team Page

SECTION: security/security-assurance/automation-and-compliance.md

Purpose

The goal of this handbook page is to document the goals and priorities for the automation in compliance within the Security Compliance team at GitLab. Automations are built and enabled through the support of GitLab's Security Assurance Automation team for technical implementations.

Core Focuses

1. Support the business by automating security processes, compliance controls, and finding automation efficiencies.
2. Develop and maintain automated solutions that enhance our security posture, streamline compliance efforts, and provide continuous monitoring of our systems and infrastructure.
3. Enable security to scale through the discovery and application of compliance automation.

Key priorities for Compliance Automation (in order)

1. Control Automations - Automated testing and alert on failures of controls
2. Control Automations - Automated testing and workbook creation
3. Metrics - Key insights into compliance/risk metrics to inform scope
4. User Access Reviews - Process automation and risk based review enablement
5. Process Automations - Process automation around compliance activities such as observation management, audit management, etc.

Possible areas of opportunity

1. Developing and implementing automated security controls and processes
2. Creating and maintaining compliance automation tools and scripts
3. Integrating security and compliance checks into CI/CD pipelines
4. Automating vulnerability scanning and remediation processes
5. Implementing automated security testing and validation
6. Developing dashboards and reporting tools for security metrics and compliance status
7. Collaborating with other security teams to identify automation opportunities
8. Continuously improving and optimizing existing compliance automation solutions

Where and How we work

- Compliance Automation leverages the workflows defined by the Security Assurance Automation Team

Metrics and Measures of Success

TBD

Automation and Compliance Roadmap

For FY25, the first Automation and Compliance Roadmap (internal-only link) was defined after a questionnaire and completed brainstorming session with Security Compliance team members.

Contact the Team

For questions related to Compliance Automation, please reach out to the sec-assurance slack channel. Issues for Compliance Automation should be opened in the Security Assurance Automation Issue Landing project as is outlined in the Security Assurance Automation handbook page.

<i class="fas fa-id-card" style="color:rgb(110,73,203)" aria-hidden="true"></i> I have questions

- Byron Boots, @byronboots, Senior Security Assurance Engineer, Compliance

SECTION: security/security-assurance/governance_and_field_security_team_charter.md

Team Charter

Mission

The mission of the Security Enablement team is to: (i) drive the development of GitLab's internal security strategy and posture through automation, security awareness, policy management, and regulatory and compliance oversight, and (ii) drive company ARR through effective and efficient customer assurance activities and external security evangelism; and support the sales organization through field security focused training and strategy alignment.

Roles and responsibilities

Please refer to the following roles and responsibilities for Security Enablement team members. All three specialties (Governance, Field Security, Sec. Assurance Automation) can be found under each job grade:

Security Assurance team member roles and responsibilities
{.h4}

High Level Core Competencies

External Security Evangelism

- External communication of security strategy via different media (audio, video, written, etc.)
- Initiatives to support thought leadership and market positioning
- Building collateral pieces to improve knowledge of internal security posture

Field Security Research

- Discovery and communication of internal and external security events to support the development of Field Security's strategy
- Empowering sales by providing internal documentation to help shorten the current sales cycle
- Highlighting topics stemming from customer feedback to inform the Security Assurance roadmap

Security Sales Enablement

- Execution of customer assurance activities
- Identifying opportunities to streamline Field Security's involvement in the sales cycle
- Develop and distribute training on Field Security processes and resources to the Sales organization
- Collaborating with the Solution Architecture team as the Customer's trusted security advisors

Automation

- Development of new automated processes
- Enhancement of existing automated processes
- Breaking complex requests into smaller manageable components
- Deployment of new Security Assurance technologies and integration with existing technologies

Policies and Awareness

- Policy and standard management
- Security awareness and role-specific training for internal team members

Compliance Monitoring and Oversight

- Awareness and communication of new or updated regulatory and compliance requirements
- Advisory work on security impacts of new compliance requirements for our customers/prospects

Metrics

- Development and maintenance of department-level metrics for Security Enablement and cross-functional Security Assurance teams.
- The Security Enablement team serves as the technical DRI for creating data sources that feed department-level metrics for all Security Assurance teams.

Program goals

Field Security

- Help to increase monthly ARR for the company through customer assurance activities
- Support customer security needs and requirements to drive customer attainment, retention, and satisfaction

- Increase awareness of GitLab's security capabilities and GitLab Inc's security controls through external evangelism activities

Governance

- Improve general internal security awareness, including Phishing awareness, for all team members
- Develop role based security training for high risk team members
- Maintain awareness of existing and new regulatory and compliance requirements, and feed that information to relevant teams for triage and action
- Develop and maintain a holistic set of policies and procedures to support regulatory, compliance, and operational requirements

Automation

- Reduce manual efforts through automation and simplification of new and existing processes
- Streamline and enhance Security Assurance tooling through native and custom built integrations and products
- Improve the effectiveness and efficiency of existing and new processes through automation
- Champion an engineering mindset for Assurance processes and programs
- Automate compliance controls and compliance control monitoring processes
- Reduce the amount of time consumed by manual tasks.
- Drive AI adoption and integration into team workflows

Program scope

Field Security

The scope of the Field Security program is company-wide. Field Security collaborates with all cross-functional teams to support the execution of customer assurance, external evangelism, and security sales enablement activities.

Governance

The scope of the Governance program is company-wide. Governance collaborates with all cross-functional teams to support security awareness, internal security evangelism, automation, policy and procedure management, and compliance monitoring and oversight activities.

Automation

The scope of the Automation program is primarily Assurance, with impacts company-wide as Security Assurance works across the company. Automation collaborates with cross-functional teams to develop automated solutions to increase security efficiency, accuracy, and scope for all other Assurance programs.

Strengths and skills

Field Security

- Great interpersonal skills

- Effective time management
- Detail oriented
- Broad understanding of security related topics
- Effective communication skills

Governance

- Process and detail oriented
- Technical acumen
- Analytical acumen
- Attention to diverse audiences
- Effective communication skills

Automation

- Technical acumen
- Analytical acumen
- Growth and efficiency mindset approach to problems
- Cross-program relationships identification and integration
- Effective communication skills

SECTION: security/security-assurance/observation-management-procedure.md

Purpose

The Observation Management Program at GitLab is used to identify, track, remediate and provide a risk ratings of identified findings, exceptions or deficiencies for any Tier 3 information system risks that are identified as an output of compliance operations or other mechanisms by team members, such as self-identification of a system specific risk.

This procedure details the creation process for observations.

Scope

Tier 3 risks or observations identified at the information system or business process levels

Roles and Responsibilities

| Role | Responsibility |

| ---- | ----- |

| Observation Manager | Responsible for being the observation DRI through the observation lifecycle including verifying and fine tuning recommended remediation plans in order to meet legal and regulatory requirements. |

| Remediation Owner | Validates observation, confirms assignee, due date, finalizes remediation plan and conducts remediation activity based on defined remediation SLA's. |

| Managers to Executive Leadership | Responsible for escalation as necessary and resource allocation for remediation activity. |

Procedure

Lifecycle Overview

mermaid

graph TD;

A[Identified] --> B[Validated];

B --> C[In Progress];

B --> D[Stalled];

B --> G[Blocked];

C --> E[Remediated];

E --> F[Remediation Accepted];

B --> H[Risk Accepted];

Observation Workflow Labels

These workflow labels indicate with the observation issue within the lifecycle.

| Label | Description |

| ----- | ----- |

| Observation Workflow:: Identified | Initial review to determine validity of observation |

| Observation Workflow:: Validated| Remediation owner has been assigned, but remediation has not started |

| Observation Workflow:: In Progress| Remediation owner has been assigned and remediation is underway |

| Observation Workflow:: Remediated| Remediation owner indicates the remediation step is complete|

| Observation Workflow:: Remediation Accepted| Indicated that the observation manager has reviewed remediation and agrees the issue is closed|

| Observation Workflow:: Risk Accepted| Observations that no remediation action will be taken and have been risk accepted by the remediation owner. Please tag @madlake in these issues.|

| Observation Workflow:: Blocked| Indicated that the observation is blocked - please indicate why in a comment|

| Observation Workflow:: Stalled| Indicated that remediation is stalled|

Observation Category Labels

Labels in this set are used to categorize issues for metrics and reporting and cross-team collaboration.

| Label | Description |

| ----- | ----- |

| Department:: | Department that is responsible for remediation |

| RiskRating:: Critical| Risk rating for security compliance observations - Critical|

| RiskRating:: High| Risk rating for security compliance observations - High|

| RiskRating:: Moderate| Risk rating for security compliance observations - Moderate|

| RiskRating::Low | Risk rating for security compliance observations - Low|

| ObservationManager:: | GitLab team member managing the observation through the observation phases. |

| Blocked:: Awaiting Remediation Owner Input | This flag indicates the observation manager is waiting for response from the remediation owner. |

| Blocked:: Awaiting Observation Manager Input | This flag indicates the issue for the observation manager on the SecAssurance team

|

| Blocked:: New tool implementation in progress | This flag indicates the issue for pending completion of the new tool

|

| Upgraded::StORM-Managed | This label will be leveraged when the observation has been upgraded to a tier 2 risk and will be managed in the StORM program

|

| Upgraded::StORM-Shared | This label will be leveraged when the observation has been upgraded to a tier 2 risk and remediation is shared by the Security Risk and Security Compliance team |

| NIST CSF Function: | Identifies observations within the NIST CSF function|

| NIST CSF Category: | Identifies observations within the NIST CSF category|

| seccomp program:| Identifies which program or external certification is affected by the observation|

| system::| Identifies what system is impacted by the observation|

Identifying Observations

Observations can be identified through the following channels:

1. Security control testing activities (CCM)
1. Business Impact Analysis (BIA) activities
1. External audit activities
1. Gap assessment activities
1. Ad-hoc issues

Assigning Observations

The observation identifier is responsible for opening an observation in the GitLab Observation Project. The observation identifier fills out all necessary observation information, remediation recommendations and submits the observation to the Remediation Owner for validation. The Observation Manager is responsible for managing the observation through the observation lifecycle. This includes linking the observation to the associated control in Hyperproof, validating the observation with the Remediation Owner, tracking all remediation progress and updating the GitLab issue with current information and status updates. Each observation has both a GitLab Issue (for Remediation Owners) and a Hyperproof Issue (for Observation Managers). Each observation will be assigned a risk rating, which should drive the priority of remediation.

Drafting Observation Description Guidance

The Observation description should include the who, what, when, where, why, and how related to the observation. As a review step, if you knew nothing about this observation could you understand the finding, how it was identified, and the effect it has on objectives? Consider leveraging the 4C's model:

1. Condition - current state
1. Criteria - desired state based on policy, requirement, control, regulation, etc.
1. Cause - root cause of the observation
1. Consequence - actual or potential effect on objectives/assets

Risk Ratings

Tier 3 information system risk ratings are based off the formula below.

> Risk Rating = Likelihood x Impact

Determine the likelihood of the observation recurring

At GitLab, observations will be rated based on the likelihood the observation has recurring and/or the frequency that the control has seen observations.

| Qualitative
 Score | Scoring Guidelines |

| :-----: | ----- |

| 4 | The control has observations that have persisted and continue to occur year to year AND/OR the observation noted is associated with the design of the control. |

| 3 | The control has had multiple observations in the current fiscal year or prior 9 months, whichever is longer. |

| 2 | The observation was identified as a result of management's oversight on the control and may potentially occur again. This is the only observation associated with the control in the current fiscal year or prior 9 months, whichever is longer. |

| 1 | The observation identified is considered to be a one off occurrence for the control as a result of extenuating circumstances. It is unlikely to occur again once remediated. |

Determine the impact of the observation

| Qualitative Score | External Audit Impact | Remediation Effort | Legal & Regulatory Impact | Financial Impact |

| :-----: | :-----: | :-----: | :-----: | :-----: |

| 4 | The observation will result in a documented finding in the audit. | The observation has remediation effort that requires support at the executive level. | The observation could directly result in major regulatory action against GitLab. | Loss of \$500,000+ |

| 3 | The observation is likely to result in a documented finding in the audit. | The observation has remediation effort that requires support at the director level. | The observation could lead to an investigation or regulatory action. | Loss between \$10,000 and \$499,999 |

| 2 | The observation would likely not lead to a documented finding in the audit because it is an isolated occurrence. | The observation has remediation effort that requires support at the management level. | The observation could lead to minor regulatory action. | Loss between \$1,000 and \$9,999 |

| 1 | The observation would not lead to a documented finding in the audit. | The observation was related to extenuating circumstances and requires simple reinforcement of policy/process, no additional management oversight required. | The observation would not lead to major action by a regulator. | Loss up to \$999. |

Determining Risk Rating

Once the likelihood and impact scores are determined, the following table can be used to determine the risk rating for the observation:

Risk Rating	Risk Score Range
	:-----: :-----:
Critical	16
High	12-15
Medium	4-11
Low	1-3

Observation Remediation

Once all remediation activities have been completed, the Remediation Owner is responsible for tagging the Observation Manager in the observation issue. If there is no Observation Manager assigned, tag @gitlab-com/gitlab-security/security-assurance/security-compliance in the observation issue.

It is the responsibility of the Observation Manager to track the milestones, work progress and validation of the remediation activity. The Observation Manager will then validate the remediation activity for completeness, re-test the observation (as applicable) and close the observation issue. If re-testing does not result in a fully effective conclusion, the observation description and remediation recommendations may be updated to reflect the new findings and required remediation tasks.

Remediation SLA

Observation remediation SLA's are determined by the risk rating of the individual observation. The following table shows the SLA for each risk rating unless otherwise defined by the agreed upon remediation plan.

Risk Rating	Remediation SLA
	:---: :---:
Critical	3 months
High	6 months
Medium	12 months
Low	18 months

Criteria for Upgrading Observations To Tier 2 Risks

<details><summary>Criteria and procedures</summary>

The observation program is a key input to the StORM program, which manages tier 2 security operational risks. When the following criteria is met, it is an indicator that a larger risk exists and is upgraded to a tier 2 operational risk and therefore included in the StORM program. This criteria is as follows:

- An observation in an entity level control
- When multiple observations share root cause and are grouped in an observation epic.

Observation epics are a group of observations spanning multiple systems that have shared root cause and remediation paths.

Security Compliance Workflow

mermaid

graph TD

```
A[Observation Opened]
A --> B{Observation meets<br>criteria for upgrading}
B --> C{Yes}
B --> |No| G(Follow Observation<br>Management Process)
C --> |Observation Epic| E[Tag Risk, apply upgraded label]
C --> |ELC| F[Tag Risk, apply upgraded label]
F --> H[Risk is managed in <br> StORM program at tier 2 level]
E --> I[Work with risk on collaborative remediation<br>for both Tier 2 and Tier 3 issues]
```

Security Risk Workflow

mermaid

flowchart TD

```
A[Risk Team is tagged in a risk<br>meeting criteria for upgrading]
A --> B{Type of<br>observation}
B --> C[ELC]
B --> D(Observation Epic)
C --> E{Does a Risk<br>already exist?}
E --> |Yes| F[Map related Risk,<br>update into risk info if appropriate]
E --> |No| H[Follow Risk<br>Runbook for new risks]
H --> G(Risk is treated and<br>managed in StORM Program)
F --> G
D --> J{Does a Risk<br>already exist?}
J --> |Yes| K[Map related Risk,<br>update into risk info if appropriate]
J --> |No| L[Follow Risk<br>Runbook for new risks]
L --> M(Work with SecComp<br>on Remediation)
K --> M
```

Detailed write up:

1. Open an observation following the Observation Intake runbook (internal only).

1. If the observation meets the criteria for being upgraded, tag the StORM DRI and apply label ~upgraded::storm-managed if an ELC or ~upgraded:storm-shared if added to an observation epic.

1. Definitions of labels:

1. Upgraded::StORM-Managed : StORM risk managers are solely responsible for tracking remediation activities

1. Upgraded::StORM-Shared : Remediation of the observation and risk is shared by the StORM risk managers and the observation manager. The StORM risk manager may track remediation activities spanning multiple systems via a common initiative, while the observation manager would be responsible for remediation of the specific system. See the collaborative remediation section for more details.

1. When the Security Risk team is tagged, someone on that team will determine if there is a risk represented for the observation meeting the criteria.

1. If there is an existing risk, they will map the observation to the risk and leave a comment in the GitLab issues for transparency.

1. If there is not an existing risk, they will open a new risk following the StORM Risk Intake runbook (internal only).

1. An entity level control, the observation will be entirely managed by the StORM program at the tier 2 risk level, represented by the Upgraded::StORM-Managed label.

1. If the Observation is not an entity level control, Security Compliance will work with Security Risk for collaborative remediation with the remediation owner(s).

Collaborative Remediation

Security Compliance and Security Risk should look for opportunities to remediate via aggregated/common controls. In the event that observations can be remediated via a common control or implementation, activities can be tracked by the Security Risk team. For example, if we have systems that are not meeting password requirements and remediation across multiple systems involves integrating with Okta, this roll-out can be tracked by Security Risk. If remediation is system-specific, remediation activities can be tracked by Security Compliance. Remediation testing will be completed by which ever team is tracking remediation activities using the Security Compliance remediation runbook.

Status Labels

Defined below are status labels that will aide in the process of managing remediation of observations.

| Label| Definition|

|--|--|

|Blocked:: Awaiting Remediation Owner Input| This flags indicates the observation manager is waiting for response from the remediation owner. |

|Blocked:: Awaiting Observation Manager Input| This flags the issue for the observation manager on the SecAssurance team|

|Blocked:: New tool implementation in progress |This flags the issue for pending completion of the new tool|

|Upgraded::StORM-Managed | This label will be leverage when the observation has been upgraded to a tier 2 risk and will be managed in the StORM program|

|Upgraded::StORM-Shared | This label will be leverage when the observation has been upgraded to a tier 2 risk and remediation is shared by the Security Risk and Security Compliance team|

</details>

Metrics and Reporting

Please refer to the observation management project's issue boards for details for all observations by risk, status, and department. Please refer to our tableau dashboard for operational metrics for the observation program.

Exceptions

Exceptions will be created for observations that breach a mutually agreed upon remediation date, breach in SLA or if the Remediation Owner confirms the observation will not be remediated.

Exceptions to this procedure will be tracked as per the Information Security Policy Exception Management Process.

References

- GCF Control Lifecycle
- Observation Management Project

Contact & Feedback

If you have any questions or feedback about the observation management process please contact the GitLab Security Assurance Team.

SECTION: security/security-assurance/production-readiness-compliance-assessment.md

The Compliance Production Readiness Assessment is a process designed to make it clear what obligations systems owners have for configuring and hardening a system/tool/service in order for GitLab to meet its compliance and regulatory obligations.

Scope

This Compliance Production Readiness Assessment process applies to new systems/tools/services or any existing system/tool/service that is processing new data or existing data in a different way that might change the compliance and regulatory obligations.

An example of a scope change would be a system like Calendly that might only be processing Yellow data today but due to a new feature is now processing Orange data. This new type of data being ingested into such a system would change the security control requirements and would require increased support from the system owner to help ensure these controls are operating effectively.

Process

1. If you have a new system that you're thinking about onboarding or an existing system that will change the type of data being processed or a system that is connecting to a new system, start by opening a Security Compliance intake issue and include the system name, data types (old and new), and system connection information. This will kick off a triage process by the Security Risk team to gather additional information.

1. Security Risk and Security Compliance will work together to determine what security controls will need to be tested and when. System owners and relevant stakeholders will be notified about these requirements

1. Testing will be scheduled based on capacity and priority and will follow the GCF Security Control Lifecycle

1. Testing will result in a system health rating and testing observations/findings (if

applicable) which will be communicated out to system owners and relevant stakeholders.

Questions about this process

Please reach out to the Security Compliance team using the @sec-compliance-team tag in the sec-assurance slack channel and we can work with any questions you have about this process.

FAQ

1. I'm just testing something with production data but don't plan to keep the data here long term. Do I need to engage with the above process?

- Yes. We have contractual obligations to our customers and the scope for our external security audits change when we store RED data in a new location regardless of how long the data will exist there.

1. I have a system processing RED data, but I have never had to engage with the above process. Do I need to do anything?

- Yes. This might be an indication that the Security Compliance teams aren't aware of this new environment which means we will need to test the system as soon as possible.

1. I am working on a demo of a tool and we are going to use actual data, but I haven't signed a contract yet. What do I need to do?

- Open an issue according to the above process. Our processes are based on the type of data being used on not whether or not we're paying for a service.

1. I have a new system that will be processing RED data or an existing system that will now be processing RED data. What requirements are there for me as a system owner?

- Open an issue according to the above process and work with Security Compliance to provide evidence and system context so we can understand the compliance or regulatory requirements.

1. Same as above for ORANGE Data

- Same requirements as RED data to start the intake process.

1. Same as above for YELLOW Data

- Same requirements as RED data to start the intake process.

1. Same as above for GREEN Data

- Same requirements as RED data to start the intake process

SECTION: security/security-assurance/security-terms-glossary.md

Overview

The Security Assurance team performs various types of security questionnaires, assessments and audits. If you have any questions, please feel free to contact us:

- Join our slack channel: sec-assurance
- Email: <security-assurance@gitlab.com>

Security Questionnaire

A document that is meant to provide an overview of a Security Program or portions thereof. Security Questionnaires are routinely used during Security Assessments. An example of an industry standard security questionnaire includes the CAIQ and which GitLab makes publicly

available in our Customer Assurance Package

Security Assessment

An activity in which a Security Program or portions thereof are investigated for fit and function. For instance GitLab conducts Third Party Risk Management assessments of our third parties. Security Assessments are generally conducted by an organization who is intending to procure services from another organization. GitLab supports Security Assessments for customers by publishing and maintaining the Customer Assurance Package

Security Audit

A comprehensive examination of a Security program, Security Relevant System or Security Controls. Security Audits are more comprehensive than security assessments as they require access to trusted information. It is important to understand the scope and covered period of a Security Audit to correctly interpret results. Security Audits can be internal or external.

Internal Security Audit

A Security Audit conducted by personnel under the employment of the organization conducting the Audit. For example the Internal Audit Team and Security Compliance Team at GitLab conduct Internal Audits of GitLab's Security Program.

External Security Audit

A Security Audit conducted by a contracted and independent 3rd party. For example GitLab routinely undergoes SOC2 audits and Penetration Testing from independent 3rd party auditors.

SECTION: security/security-assurance/technical-and-organizational-measures.md

Technical and Organizational Security Measures for GitLab Cloud Services

GitLab Cloud Services (including GitLab.com and GitLab Dedicated) meet the specific requirements of data protection, including, without limitation, Article 28 of the General Data Protection Regulation and which are listed as SOC 2 Type 2 (Security & Confidentiality).

At a minimum, GitLab has implemented for the GitLab Cloud Services the technical and organizational measures and maintains security practices within the production environments as follows:

Confidentiality of processing systems

Identity and Access Management

- Predefined security groups are utilized to assign role-based access privileges and segregate access to data to the production systems.
- Administrator access to the production systems is granted based on job roles and responsibilities and limited to authorized personnel.

Audit Assurance: Compliance, Governance and Risk Management

- GitLab performs annual security operational risk assessments of production applications and services. Results from risk assessment activities are documented in a risk register and prioritized for treatment based on risk level.
- GitLab performs a vendor security review for third-party vendors whose services will store, process or transmit GitLab and/or GitLab customer data.
- GitLab performs risk-based continuous control monitoring throughout the year by performing control testing using a formal methodology. The testing results are documented and reviewed by management, including remediation plans for identified observations.
- Controlled documents are reviewed, approved by management, and communicated to relevant employees annually.

Human Resources

- GitLab team members complete security awareness training upon hire and annually thereafter. The training includes relevant GitLab security policies, instructions for reporting security incidents and general industry security best practices.
- GitLab new hires are required to pass a background check as a condition of their employment.

Integrity of processing systems

Application & Infrastructure Security

- Infrastructure management and configuration management tools are used for security hardening and to ensure baseline configuration standards have been established for production servers.
- Network traffic to and from untrusted networks passes through a policy enforcement point; firewall rules are configured to prevent unauthorized access.
- An issue tracking system is in place to centrally maintain, manage, and monitor application and infrastructure changes from development through implementation.

Threat and Vulnerability Management

- GitLab conducts scoped vulnerability scans against the production environment to identify threats and assess their potential impact to the system on a weekly basis. Results are evaluated and remediated according to severity level.
- GitLab executes a 3rd party application penetration test on an annual basis, a process which includes additional 3rd party remediation testing if any high or moderate risk vulnerabilities are identified.
- Monitoring tools are used to continuously monitor security events, latency, network performance, and virtual server performance.
- Incident response procedures are in place that outline the response procedures to security events and includes lessons learned to evaluate the effectiveness of the procedures.

Availability of processing systems

Resilience

- A business continuity plan is in place to guide personnel in procedures to protect against disruptions caused by an unexpected event. Tabletop exercises are completed on an annual basis.

- Enterprise monitoring applications are configured to monitor in scope system capacity levels and alert operations personnel when predefined thresholds have been met.

Additional Considerations

- The GitLab application is designed to allow customers to delete their own data wh